Detectando lo que las reglas y las líneas base no ven: UEBA basado en series de tiempo

Alejandro Higuera Castro

Departamento de Estadística, Facultad de Ciencias
Universidad Nacional de Colombia, Sede Bogotá, Colombia
ahiguerac@unal.edu.co

Resumen Los centros de operaciones de seguridad (SOC) buscan amenazas internas con reglas de umbral y líneas base estáticas que generan tantas falsas alarmas que desgastan y desensibilizan a los analistas. Este trabajo trata la actividad de cada usuario como una serie de tiempo con ciclo semanal y aplica la metodología Box-Jenkins a la analítica del comportamiento de usuarios (UEBA): cada noche, un modelo SARIMA por usuario y contador pronostica nueve contadores de actividad, mide cuánto se aleja lo observado de lo normal para ese usuario y entrega al SOC los casos más anómalos del día. En CERT r4.2 (1.000 usuarios, 500 días, 70 incidentes), con las mismas 10 alertas diarias que una regla global y una línea base estática, SARIMA encuentra 240 días maliciosos frente a 163 de la estática (+47 %) y 67 de 70 incidentes (estática, 64; global, 17).

Palabras clave: Amenaza interna · UEBA · Series de tiempo · SARIMA · Detección de anomalías · Fatiga de alertas

1. Introducción

La detección por firmas es eficaz ante amenazas conocidas, pero en gran medida ineficaz ante las desconocidas [5]. Una persona puede usar credenciales válidas para acciones maliciosas (MITRE ATT&CK T1078): lo anómalo es el patrón. Los SOC usan reglas de umbral y perfiles [5], pero un umbral fijo trata igual un lunes que un domingo: dispara con actividad normal y calla ante anomalías que no lo alcanzan. Los analistas reconocen que casi todas sus alarmas son falsos positivos y que revisarlas desgasta y desensibiliza [1], y así se pierden ataques [3].

La actividad de un usuario, como el tráfico de red [2], es una serie de tiempo: tiene ciclos diarios y semanales y depende de su historia. Por eso la línea base debería ser un modelo de series de tiempo por usuario. La pregunta es práctica: con las alertas que un SOC puede revisar, ¿ese modelo detecta más que una regla global y que una línea base estática, y cuánto aporta el ciclo semanal? El aporte es una analítica con modelos Box-Jenkins interpretables, uno por usuario y contador, evaluada con igual carga de trabajo y sin remuestrear (0,32 % de días maliciosos), frente a redes profundas como BRITD [6] y BTITD [8].

2. Datos y método

Datos. CERT r4.2 [4] simula 1.000 usuarios durante 500 días con registros de sesiones, USB, archivos, correo, web y directorio. Su registro de incidentes describe 70 casos: fuga de información a WikiLeaks fuera de horario (30), robo de datos antes de renunciar (30) y sabotaje con la cuenta del supervisor (10). Un usuario-día es malicioso si tiene un evento del incidente.

Cómo funciona. La analítica corre como un proceso nocturno: (1) un proceso de extracción resume los registros en nueve contadores por usuario y día (sesiones, USB, archivos, correo y web, también fuera de 07:00 a 19:00); (2) para cada usuario y contador, un modelo pronostica el valor esperado del día y su *límite del 99 %*, el valor que un día normal no debería superar más de 1 vez de cada 100; (3) el puntaje del usuario es el mayor exceso sobre su pronóstico, en desviaciones estándar; (4) el SOC revisa los k usuarios con mayor puntaje. Los modelos usan $\log(1 + \text{conteo})$ y solo cuentan los aumentos.

Modelos. Se comparan la regla global (un umbral para todos), la línea base estática (media y desviación de cada usuario, recalculadas cada mes), la regla ingenua (hoy igual que hace una semana), ARIMA, SARIMA y SARIMAX (con la mediana del departamento). Box-Jenkins mostró estructura temporal: de 5.700 series con actividad, el 94 % tiene ciclo semanal y en el 96 % ADF (sin el promedio de cada día) y KPSS son compatibles con estacionariedad; por AIC se eligió SARIMA$(0, 0, 0)(1, 0, 1)_7$. Sus coeficientes ($\Phi \approx 1$, $\Theta \approx -1$) lo vuelven, en la práctica, un perfil por día de la semana que se actualiza lentamente; las series casi vacías (37 % de los ajustes) usan la media del usuario.

Evaluación. Se entrena hasta el 2010-06-09, antes de cualquier incidente, y se prueba hasta el 2011-05-16, reentrenando cada mes con 182 días, sin usar etiquetas [7], o, como control, una sola vez. Se mide cuánto se detecta con k alertas diarias y la precisión promedio (PR-AUC; al azar, 0,0032), con intervalos de confianza (IC) del 95 % por bootstrap de usuarios.

3. Resultados

Con igual carga de trabajo, los tres modelos de series de tiempo superan a las reglas en toda la Tabla 1. Con 10 alertas diarias, SARIMA encuentra 240 días maliciosos, frente a 163 de la estática (+47 %; IC del 95 % de la diferencia: 43 a 117) y 36 de la regla global. SARIMA supera a la estática con 1 a 30 alertas diarias, aun sin reentrenar, y en PR-AUC (+0,0062; IC: 0,0025 a 0,0108).

Sin tope diario, la regla global dispara 108 alertas al día (98 de cada 100 falsas); SARIMA, 18,5. La línea base estática necesita 18 alertas diarias para alcanzar los 240 días de SARIMA con 10. Un perfil por día de la semana, otro enfoque temporal usado como control, también supera a la estática (210 días y 67 incidentes con 10 alertas diarias): lo decisivo es el ritmo semanal. La ventaja se concentra en el robo de datos antes de renunciar, con 861 de los 986 días maliciosos; el póster (pág. 4) muestra un caso. El límite es conservador: los días normales lo superaron entre 0,2 % y 0,8 % de las veces según el contador

Tabla 1. Detecciones con igual número de alertas diarias. Negrita: mejor valor.

	Días maliciosos detectados (de 986)				Con 10 alertas diarias		
Detector	3/día	5/día	10/día	20/día	Incidentes	Aciertos/100	PR-AUC
Regla global	16	19	36	42	17/70	1,1	0,0125
Línea base estática	52	82	163	258	64/70	4,8	0,0270
Regla ingenua	32	53	93	157	46/70	2,7	0,0118
ARIMA	**85**	126	220	293	**67/70**	6,5	**0,0346**
SARIMA	81	**146**	**240**	300	**67/70**	**7,0**	0,0331
SARIMAX	83	131	234	**305**	65/70	6,9	0,0330

(nominal, 1 %). En PR-AUC no hubo evidencia de diferencias entre los tres modelos, pero SARIMA es el más estable: sin reentrenar conserva su PR-AUC (0,0339) y ARIMA cae a 0,0204, bajo la estática (0,0277). Ljung-Box no rechaza la ausencia de autocorrelación en el 82 % de los ajustes de SARIMA (se esperaría 95 %) y en el 9 % de ARIMA.

4. Conclusiones

Un modelo de series de tiempo aprende el ritmo de cada usuario y un umbral fijo no: con las mismas alertas, los tres modelos detectan entre 35 % y 47 % más días maliciosos que la estática y SARIMA, 6,7 veces los de la regla global; el analista revisa 14,2 alertas por hallazgo en vez de 20,9, lo que ayuda a reducir la fatiga de alertas. El ritmo semanal hay que estimarlo: repetir el día de la semana anterior encuentra 93 días, no 240. No ve costumbres del usuario ni acciones sin cambio de volumen; ahí sirven la regla global, el EDR y las firmas. Muestra viabilidad en datos sintéticos; una alerta no confirma un ataque.

Referencias

1. Alahmadi, B.A., Axon, L., Martinovic, I.: 99 % false positives: A qualitative study of SOC analysts' perspectives on security alarms. In: 31st USENIX Security Symposium (2022)
2. Brutlag, J.D.: Aberrant behavior detection in time series for network monitoring. In: 14th Systems Administration Conference (LISA 2000). pp. 139–146. USENIX (2000)
3. Hassan, W.U., et al.: NoDoze: Combatting threat alert fatigue with automated provenance triage. In: NDSS Symposium (2019)
4. Lindauer, B.: Insider threat test dataset (2020). `https://doi.org/10.1184/R1/12841247.v1`
5. Scarfone, K., Mell, P.: Guide to intrusion detection and prevention systems (IDPS). Tech. Rep. SP 800-94, National Institute of Standards and Technology (2007)
6. Song, S., Gao, N., Zhang, Y., Ma, C.: BRITD: behavior rhythm insider threat detection with time awareness and user adaptation. Cybersecurity **7**, 2 (2024)
7. Tashman, L.J.: Out-of-sample tests of forecasting accuracy: an analysis and review. International Journal of Forecasting **16**(4), 437–450 (2000)
8. Zhang, C., et al.: BTITD: an insider threat detection method based on behavior-timestamp dual-stream network. Cybersecurity **9**, 179 (2026)

7ma Jornada de Ciberseguridad de la Universidad Nacional de Colombia

2026

Detectando lo que las reglas y las líneas base no ven: UEBA basado en series de tiempo

Resumen

Las series de tiempo detectan mucho más actividad maliciosa que los métodos tradicionales evaluados. Este trabajo trata la actividad de cada usuario como una **serie de tiempo con ciclo semanal**: un modelo SARIMA por usuario y contador estima cuánto es normal cada día y el centro de operaciones de seguridad (SOC) revisa los mayores aumentos. En CERT r4.2 (1.000 usuarios, 70 incidentes simulados), con 10 alertas diarias, SARIMA identifica **240 días maliciosos: 47 % más que la línea base estática por usuario y 6,7 veces los de la regla global**, y cubre 67 de 70 incidentes. Tiene potencial para reducir el trabajo de los equipos de seguridad y la fatiga de alertas: el analista revisa 14 alertas por hallazgo en vez de 21.

Propósito

Evaluar si incorporar la historia y el ciclo semanal de cada usuario permite identificar más actividad maliciosa con el mismo número de alertas para revisar.

> **¿Es normal que *este* usuario haga *esto*, *este día* y con *esta* intensidad?**

Contexto e importancia

- **Las firmas no bastan:** detectan lo conocido (NIST SP 800-94), pero una persona puede usar credenciales válidas para acciones maliciosas (MITRE ATT&CK T1078): lo anómalo es el patrón.
- **Las reglas de umbral generan ruido.** Un analista de SOC lo resume así: "Sabemos que el 99 % de las alarmas que generamos son falsos positivos, pero aun así tenemos que revisarlas" (Alahmadi et al., 2022; traducción propia). Con demasiadas alertas se pierden ataques reales (Hassan et al., 2019).
- **La actividad es una serie de tiempo**, como el tráfico de red (Brutlag, 2000; Rajchel et al., 2020): en estos datos, el 94 % de las series con actividad tiene ciclo semanal.

¿Qué ve que una regla no ve?

- **Robo de datos antes de renunciar:** el modelo de cada usuario capta el aumento de memorias USB (SARIMA, 28 de 30; ARIMA, 30; línea base estática, 25; regla global, 2).
- **Sesiones fuera de 07:00 a 19:00, raras para ese usuario:** señal principal en 19 de las 30 fugas a WikiLeaks (SARIMA y la línea base estática las detectan todas; la regla global, 7).
- **Lo que no ve:** lo que ya es costumbre del usuario (un robo con USB fuera de horario que la regla global sí detecta) y las acciones sin cambio de volumen. Requiere complementarse con otros controles.

Conclusiones

- **Las series de tiempo superan con claridad a los métodos tradicionales evaluados:** con las mismas alertas, los tres modelos detectan entre 35 % y 47 % más días maliciosos que la línea base estática, y SARIMA 6,7 veces los de la regla global.
- **La ventaja viene del ritmo semanal:** modelarlo (SARIMA o un perfil por día de la semana) supera a la estática; copiar la semana anterior no basta (93 días).
- **Menos ruido para el SOC:** menos alertas por hallazgo ayuda a reducir la fatiga de alertas. CERT es sintético: falta validarlo en una organización real.

Glosario

Día malicioso: día de un usuario con alguna acción de un incidente (986 en la prueba); un incidente se detecta si alguno de sus días entra en las alertas.
UEBA: análisis que aprende lo normal de cada usuario y avisa cuando se aparta.
Serie de tiempo: un dato que se mide día tras día, como las memorias USB conectadas.
Regla global: el mismo umbral para todos los usuarios de la organización.
Línea base estática: promedio y variación de cada usuario, recalculados cada mes; un solo límite.
Regla ingenua: supone que hoy será igual al mismo día de la semana anterior.
Perfil semanal: promedio de cada usuario para cada día de la semana.
ARIMA: pronóstico con los días inmediatamente anteriores; el evaluado no incorpora el ciclo semanal.
SARIMA: versión estacional de ARIMA: incorpora un ciclo de siete días y actualiza la expectativa con la historia observada; espera más actividad un lunes que un domingo.
SARIMAX + pares: SARIMA que además mira la actividad del día en su departamento.

Método

1. Registros
32,8 M eventos de sesiones, USB, archivos, correo y web

2. Contadores diarios
9 por usuario, en escala log(1 + conteo)

3. Patrón esperado
SARIMA semanal por usuario y contador, reentrenado cada mes (ciclo semanal en el 94 % de las series)

4. Cola de revisión
los 10 usuarios con mayor aumento sobre lo esperado, cada día

Límite del 99 %: el valor que un día normal de ese usuario no debería superar más de 1 vez de cada 100 en ese contador (en la prueba, 2 a 8 de cada 1.000). Solo cuentan los aumentos. **Diseño:** 1.000 usuarios; entrenamiento hasta el 9 de junio de 2010, sin incidentes; prueba hasta el 16 de mayo de 2011. Las series casi vacías (37 % de los ajustes) usan la media del usuario.

Resultados

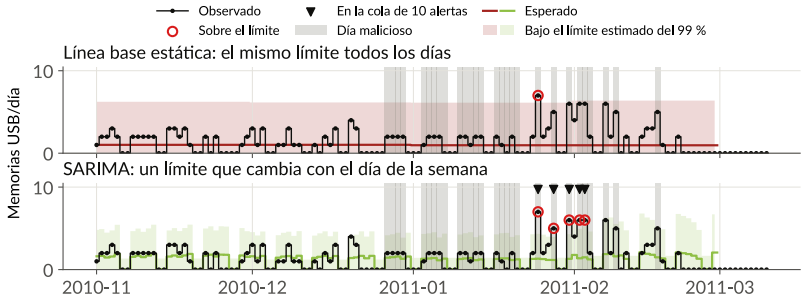


Figura 1. Robo de datos antes de renunciar (empleado IKR0401), uno de los 3 robos que SARIMA prioriza y que ni la regla global ni la línea base estática priorizan con 10 alertas diarias. Círculos: días sobre el límite por contador; triángulos: días que entraron en la cola de 10 alertas. SARIMA marca 5 de los 28 días maliciosos y los 5 entran en su cola; la línea base estática marca 1, que no entra en la suya.

Detector	Días maliciosos detectados (de 986)	Incidentes detectados (de 70)	Aciertos por cada 100 alertas
Regla global	36	17/70	1,1
Línea base estática	163	64/70	4,8
Regla ingenua	93	46/70	2,7
Perfil semanal (control)	210	**67/70**	6,2
ARIMA	220	**67/70**	6,5
SARIMA	**240**	**67/70**	**7,0**
SARIMAX + pares	234	65/70	6,9

Tabla 1. Con 10 alertas diarias y reentrenamiento mensual. Los enfoques temporales (abajo) superan a los tradicionales (arriba). El perfil por día de la semana es un control que también modela el ciclo semanal: con 20 alertas diarias encuentra 322 días; SARIMA, 300.

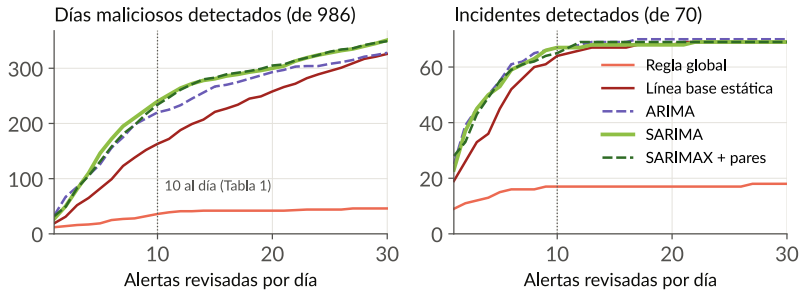


Figura 2. Con 1 a 30 alertas diarias, los tres modelos de series de tiempo detectan más días maliciosos que la línea base estática, sobre todo con pocas alertas (hasta +78 %, con 5); la regla global no pasa de 18 incidentes.

Hallazgos clave

- **47 % más y 6,7 veces más con las mismas alertas:** con 10 alertas diarias, SARIMA identifica 240 de 986 días maliciosos; la línea base estática, 163, y la regla global, 36. Diferencia con la estática: 77 días (IC bootstrap del 95 %: 43 a 117).
- **Más aciertos por alerta:** 7,0 de cada 100 alertas de SARIMA corresponden a días maliciosos, frente a 4,8 de la línea base estática y 1,1 de la regla global.
- **La línea base estática exige casi el doble:** necesita 18 alertas diarias para alcanzar los 240 días que SARIMA encuentra con 10.
- **Un umbral fijo satura:** con su propio límite del 99 % y sin tope diario, la regla global dispara 108 alertas al día (98 de cada 100 falsas); SARIMA, 18,5.
- **El ritmo semanal es la clave:** sin reentrenar, SARIMA mantiene 233 días maliciosos y ARIMA, que no incorpora el ciclo semanal, cae a 123 (la estática, 171).

Referencias

Alahmadi, B. A. et al.: 99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms. USENIX Security (2022).
Brutlag, J. D.: Aberrant Behavior Detection in Time Series for Network Monitoring. USENIX LISA (2000).
Hassan, W. U. et al.: NoDoze: Combatting Threat Alert Fatigue with Automated Provenance Triage. NDSS (2019).
Lindauer, B.: Insider Threat Test Dataset. Carnegie Mellon University (2020). doi:10.1184/R1/12841247.v1
Rajchel, B. et al.: Temporal Behavior in Network Traffic as a Basis for Insider Threat Detection. IEEE SSCI (2020).
Scarfone, K., Mell, P.: Guide to Intrusion Detection and Prevention Systems. NIST SP 800-94 (2007).
Tashman, L. J.: Out-of-sample tests of forecasting accuracy. Int. J. Forecasting 16(4) (2000).

Autor(es):

Alejandro Higuera Castro
Departamento de Estadística
Facultad de Ciencias
Universidad Nacional de Colombia

Organiza:

Universidad Nacional de Colombia
Semillero de Investigación Uqbar
Grupo de investigación Tlön